

Activación de MFA TOTP

Flujo completo de activación, verificación en dos pasos al iniciar sesión, recuperación con códigos de respaldo y desactivación de la autenticación multifactor basada en RFC 6238 (TOTP · 6 dígitos · período 30 s).

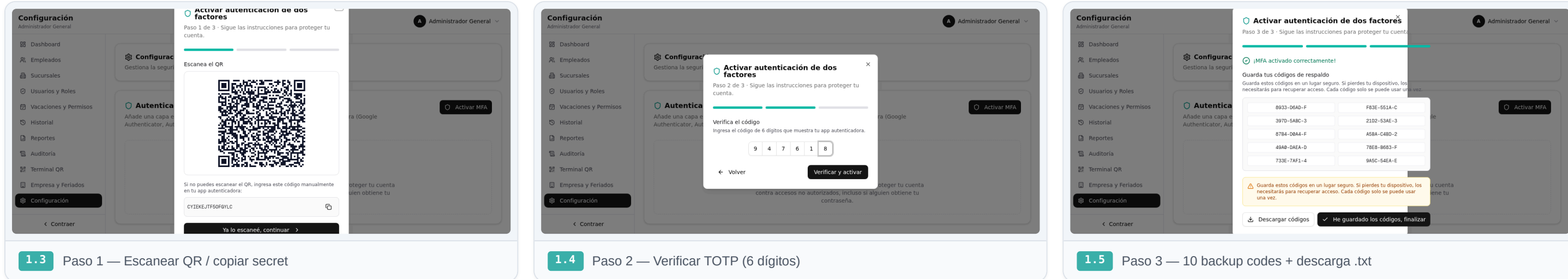
NextAuth.js v4 · JWT AES-256-GCM
otplib RFC 6238 · bcrypt cost 10
5 fases · 22 pasos
control-asistencia-v22.vercel.app

1 FASE 1 — Activación de MFA

Rol: GENERAL_ADMIN · SUCURSAL_ADMIN

- Ir a “Configuración” en el panel admin (entrada del sidebar con icono engrane). Solo visible para roles `GENERAL_ADMIN` y `SUCURSAL_ADMIN`.
- Click “Activar MFA” → se abre `Dialog` de 3 pasos (estado `step` local en `SettingsView`).
- Paso 1: escanear QR con app autenticadora (Google Authenticator, Authy, 1Password) o copiar **secret base32** manualmente. Origen: `POST /api/auth/mfa/setup` → devuelve `otpauth_uri` + `qrDataUrl`.
- Paso 2: ingresar código TOTP de 6 dígitos en `InputOTP` → click “Verificar y activar”. Backend: `POST /api/auth/mfa/verify` valida con `authenticator.verify()` y marca `mfaEnabled = true`, `mfaEnrolledAt = now()`.
- Paso 3: guardar los **10 backup codes** en lugar seguro (botón “Descargar códigos” genera `.txt` vía `Blob` + `URL.createObjectURL` + `<a download>`).
- Click “He guardado los códigos, finalizar” → MFA queda **activo**. Badge verde `mfaEnabled = true` persistido en DB. Cierre del dialog y refresh de estado MFA.

CAPTURAS REALES DEL SISTEMA · DIALOG DE ACTIVACIÓN (3 PASOS)



2 FASE 2 — Login con MFA

Rol: Usuario con MFA activo

- Ir a la URL del sistema: `https://control-asistencia-v22.vercel.app`
- Ingresar **email + password** → click “Iniciar sesión”. Frontend envía `POST /api/auth/login` con `{ email, password }`.
- El sistema detecta `mfaEnabled = true` en `validateCredentials()` → responde `200 { needsMfa: true, email }`. Frontend cambia a vista “Verificación en dos pasos” (icono `Shield`).
- Abrir app autenticadora → copiar código TOTP actual (6 dígitos, válida **30 s** · params `digits=6, period=30, algorithm=SHA1`).
- Ingresar código en `InputOTP` → click “Verificar y entrar”. Frontend re-envía `POST /api/auth/login` con `{ email, password, mfaToken }`.
- Sesión creada con `mfaVerified: true` en JWT NextAuth → acceso al panel. Cookie `next-auth.session-token` (httpOnly, `SameSite=strict`, `secure` en prod, maxAge 8 h, rotación 30 min).



2.3–2.5 Login — “Verificación en dos pasos” (InputOTP 6 + botón respaldo)

3 FASE 3 — Recuperación con backup code

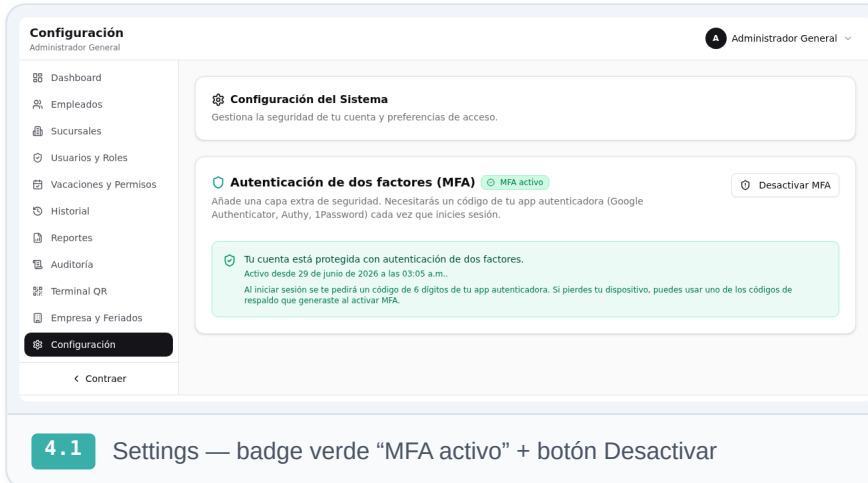
Rol: Usuario con MFA activo, sin dispositivo TOTP

- Ir a la URL del sistema.
- Ingresar email + password → click “Iniciar sesión”.
- El sistema pide MFA (paso 2 de login) → click “Usar código de respaldo en su lugar” (toggle `useBackupCode = true`; el `InputOTP` se reemplaza por input de texto).
- Ingresar uno de los **10 backup codes** guardados (formato `XXXX-XXXX-XXXX-XXXX`, *case-insensitive*, normalizado a `UPPERCASE` antes de comparar).
- Click “Verificar y entrar” → backend recorre `JSON.parse(mfaBackupCodesHash)` comparando con `bcrypt.compare()`. Si matchea: **backup code consumido** (one-time use — el hash correspondiente se remueve del array y se persiste `mfaBackupCodesHash` actualizado).
- Sesión creada con `mfaVerified: true` → acceder al panel. **Acción recomendada:** re-configurar MFA con nuevo dispositivo (Fase 4 → Fase 1) para reponer el código consumido.

4 FASE 4 — Desactivar MFA (opcional)

Rol: Usuario autenticado con MFA activo

- Ir a “Configuración” → ver badge verde “MFA activo” + fecha `mfaEnrolledAt` formateada con `Intl.DateTimeFormat('es-MX', ...)`.
- Click “Desactivar MFA” → se abre dialog de 1 paso con warning amber (confirmación intencional).
- Ingresar código TOTP actual o un backup code (toggle, misma UI que login: `InputOTP` ↔ input texto).
- Click **confirmar** → `POST /api/auth/mfa/disable`. Backend limpia: `mfaSecret = null`, `mfaBackupCodesHash = null`, `mfaEnabled = false`, `mfaEnrolledAt = null`. Toast + refresh.



4.1 Settings — badge verde “MFA activo” + botón Desactivar

5 FASE 5 — Seguridad técnica

TÉCNICO Referencia para admins técnicos

5.1 · SECRET

Secret TOTP encriptado con **AES-256-GCM** en DB. Clave derivada de `NEXTAUTH_SECRET` vía `SHA-256`. Formato almacenado: `IV(12) || AuthTag(16) || ciphertext` en base64.

5.2 · BACKUP

Backup codes hasheados con **bcrypt** (cost 10). Almacenados como `JSON array` en `mfaBackupCodesHash`. Solo se muestran **una vez** durante el setup.

5.3 · JWT

NextAuth JWT firmado (JWE) con `NEXTAUTH_SECRET`. Claim `mfaVerified: boolean` incluido en token y sesión. `maxAge = 8 h`, rotación cada `30 min`.

5.4 · LOCKOUT

Tras **5 intentos fallidos** → cuenta bloqueada **15 min** (`lockedUntil = now + 15 min`). `failedLoginAttempts` se resetea en login exitoso.

5.5 · ONE-TIME

Backup codes son **one-time use**: al consumirse, el hash se remueve del array en DB. Si se agotan, se recomienda re-enrolar MFA para regenerarlos.